

INC-2026-004

Multi-Source Reconnaissance Campaign — Sandbox-Evasion Fingerprinting Script

Cowrie SSH Honeypot | Wazuh SIEM | rpilab (agent 017)

1. INCIDENT OVERVIEW

Ticket ID	INC-2026-004
Title	Multi-Source Reconnaissance Campaign with Sandbox-Evasion Fingerprinting Script
Analyst	Jacek Kaplon
Severity	HIGH
Detection Source	Wazuh Manager — Rule 100202 (SSH Intrusion) + Rule 100203 (Critical Activity)
First Event	2026-07-01 03:52:06 BST — Wave 1 login success from 91.92.40.12
Last Event	2026-07-01 17:20:05 BST — Final failed login attempt from 193.32.162.84
Sensor Node	rpilab (agent.id: 017) 192.168.1.11
Classification	TRUE POSITIVE — Multi-Wave Automated Reconnaissance Campaign
Status	CLOSED — Detection rule 100203 fixed and validated

2. THREAT ACTOR PROFILE

Source IPs	91.92.40.12 80.94.92.55 92.118.39.71 193.32.162.84
Shared Tool Marker	SHELL_BEHAVIOR / ===DONE=== / path_err= / cmd_err= (unique strings present in all 4 waves)
Protocol	SSH
Total Waves	4 (sequential, covering 13.5-hour window: 03:52–17:20 BST)
Total Successes	51 login SUCCESS events (rule 100202) across all 4 source IPs
Total Failures	73 login FAILED events (rule 100201) across all 4 source IPs
Sensor	Cowrie SSH honeypot log: /home/pi/cowrie/logs/cowrie.json
data.eventid chain	cowrie.login.success → cowrie.command.input (per cycle, per wave)

3. ATTACK TIMELINE

All four waves executed an identical multi-stage bash fingerprinting/evasion script. Timeline built from OpenSearch REST queries against `wazuh-alerts-4.x-2026.07.01`, filtered per source IP, full 00:00–23:59 range verified for each address.

#	Source IP	Window (BST)	Duration	✓ Login	✗ Login	Rate	Pattern
1	91.92.40.12	03:52:06 – 03:53:30	~1.5 min	2	0	100%	Short probe; stops after 2 cycles
2	80.94.92.55	10:11:33 – ~12:50:12	~2.6 h	16	52	24%	Recon phase → extended failed-login run

INC-2026-004

Multi-Source Reconnaissance Campaign — Sandbox-Evasion Fingerprinting Script

Cowrie SSH Honeypot | Wazuh SIEM | rpilab (agent 017)

#	Source IP	Window (BST)	Duration	✓ Login	✗ Login	Rate	Pattern
3	92.118.39.71	13:04:50 – 13:37:48	~33 min	6	0	100%	All successes; stops at peak effectiveness
4	193.32.162.84	15:30:35 – 17:20:05	~1h 50min	27	21	56%	Phase A: recon loop ~2:24 interval → Phase B: 21 consecutive failed logins

Wave 4 detail (193.32.162.84 — primary actor):

- 15:30:35 BST | Rule 100202 (sev 7) | SSH LOGIN SUCCESS — 193.32.162.84 | First cycle of uninterrupted recon loop
- 15:30:37 BST | Rule 100203 (sev 10) | CRITICAL: Full fingerprint/evasion script executed (OS, arch, CPU, GPU, shell-error probe)
- 15:30:37–16:35:57 BST | 27 identical cycles at ~2:24 interval | MITRE: T1082 + T1497 + T1059
- 16:35:57 BST | Rule 100202 (sev 7) | FINAL successful login — last cycle of recon phase
- 16:38:11 BST | Rule 100201 (sev 5) | Phase B begins — credentials no longer accepted; 21 consecutive FAILED logins
- 17:20:05 BST | Rule 100201 (sev 5) | Final event — 193.32.162.84 goes silent for remainder of day (verified 17:20–23:59)

Key timing observation: Login-to-command latency consistently 1–2ms across all waves — confirming fully automated, non-interactive execution. Human typing is physically impossible at this speed.

4. INVESTIGATION & ROOT CAUSE

Attack Pattern: Four sequential waves of automated SSH credential stuffing followed by immediate deployment of a shared, purpose-built reconnaissance and sandbox-evasion script. The script's unique literal markers (SHELL_BEHAVIOR, ===DONE===, path_err=, cmd_err=) were identified across all four source IPs — confirming shared tooling rather than coincidence. This is consistent with either a malware-as-a-service toolkit or a publicly leaked/shared script deployed independently by multiple operators.

Script Capability Analysis:

- OS / architecture fingerprinting via uname fallback chain (native → /bin → /usr/bin → busybox → /proc/version → /etc/os-release)
- CPU profiling: core count (nproc), model (grep cpuinfo / lscpu / dmidecode), uptime (/proc/uptime)
- GPU profiling: lspci | grep -i vga/nvidia — targets crypto-mining capable hardware; also aids VM detection
- Login history: last command — checks for other active/recent sessions
- Sandbox/honeypot evasion (T1497): SHELL_BEHAVIOR block deliberately executes non-existent binaries (./xxxxxx, xxxxxx) and captures exact error format — real bash vs Cowrie emulation produce subtly different output, allowing the script to detect honeypot environments

MITRE ATT&CK; Chain:

INC-2026-004

Multi-Source Reconnaissance Campaign — Sandbox-Evasion Fingerprinting Script

Cowrie SSH Honeypot | Wazuh SIEM | rpilab (agent 017)

MITRE ID	Technique	Tactic	Evidence
T1110	Brute Force	Credential Access	73 failed logins across all 4 waves
T1078	Valid Accounts	Initial Access	51 successful logins — honeypot credentials accepted
T1082	System Information Discovery	Discovery	uname / cpuinfo / /proc/version / /etc/os-release — every cycle
T1497	Virtualization/Sandbox Evasion	Defense Evasion	SHELL_BEHAVIOR block — non-existent binary error probing
T1059	Command & Scripting Interpreter	Execution	Single multi-stage bash one-liner per session

Detection Rule Defect — Rule 100203: During timeline reconstruction, a reproducible defect was identified: every wave generated one malformed alert per cycle showing literal `$(input)` and `$(src_ip)` placeholders instead of actual values. Root cause: Wazuh's rule-description substitution engine fails to interpolate `$(input)` when the field exceeds its length/character limit (the ~1,900-character one-liner). Shorter commands in the same session substituted correctly. Source JSON was confirmed well-formed — this is a SIEM engine limitation, not a decoder fault.

5. CONTAINMENT & REMEDIATION

Containment	Cowrie honeypot emulation layer contained all sessions — no production system access
Credentials Exposed	Multiple honeypot credentials captured across 4 source IPs — not valid on production systems
Rule 100203 Fix	Removed unsafe <code>\$(input)</code> substitution from rule description; <code>\$(src_ip)</code> retained. Full command remains queryable via <code>data.input</code> field — no forensic data lost.
Validation Steps	Backup → xmllint XML validation → wazuh-logtest replay of longest command → systemctl restart wazuh-manager → confirmed active (running)
Secondary Finding	Duplicate <code>cowrie_custom</code> decoder definitions found in two separate files with differing <code>src_ip</code> regex — flagged for cleanup (latent non-determinism risk)
Recommended Actions	Block all 4 source IPs at MikroTik edge; submit IOCs to threat intel feeds; add correlation rule for <code>SHELL_BEHAVIOR/gpu_info</code> script signature

6. ANALYST COMMENTS & LESSONS LEARNED

This incident represents the most technically sophisticated attack captured by the honeypot to date. Unlike INC-2026-003 (confirmed malware execution), this campaign remained at the reconnaissance stage — but deployed a significantly more advanced tool: a purpose-built script combining hardware profiling with active honeypot-detection logic. The GPU profiling element (`lspci | grep nvidia/vga`) is characteristic of crypto-mining botnets selecting high-value targets, while the `SHELL_BEHAVIOR` evasion block demonstrates awareness of honeypot deployment in the wild.

Key observations:

- Cross-IP correlation via shared script marker (`SHELL_BEHAVIOR`) enabled campaign attribution across 4 unrelated source IPs — demonstrating the value of IOC pivoting beyond simple IP/domain matching
- Wazuh correctly escalated severity: 100201 (sev 5, failed) → 100202 (sev 7, success) → 100203 (sev 10, critical) — effective rule correlation confirmed

INC-2026-004

Multi-Source Reconnaissance Campaign — Sandbox-Evasion Fingerprinting Script

Cowrie SSH Honeypot | Wazuh SIEM | rpilab (agent 017)

- Wave 4 (193.32.162.84) showed a clear two-phase behavioural shift: sustained ~2:24 reconnect loop (Phase A) followed by 21 consecutive failed logins (Phase B) — consistent with credential expiry/rotation
- Success rate divergence between waves (100% for Waves 1 & 3 vs 24–56% for Waves 2 & 4) suggests independent operators with different credential lists rather than single centralised C2
- Detection engineering: rule 100203 defect was identified, root-caused (substitution length limit), and fixed during the same investigation — demonstrating integrated detection improvement, not just alert triage
- OpenSearch REST API (curl + jq) used throughout — no GUI required; queries reproducible and auditable

7. INDICATORS OF COMPROMISE (IOC) SUMMARY

Type	Value	Context
IP Address	91.92.40.12	Wave 1 — short validation probe, 2 cycles
IP Address	80.94.92.55	Wave 2 — 16 success / 52 failed
IP Address	92.118.39.71	Wave 3 — 6 success / 0 failed
IP Address	193.32.162.84	Wave 4 (primary) — 27 success / 21 failed
Script Marker	SHELL_BEHAVIOR / ===DONE===	Unique literal strings present in all 4 waves
Script Marker	path_err= / cmd_err=	Sub-markers from sandbox-evasion block
Command Pattern	export PATH=...; uname=\$(uname -s -v -n -m ...)	Opening line of fingerprint script — consistent across all waves
Behavioural IOC	lspci grep -i vga/nvidia	GPU profiling — crypto-miner / VM-detection indicator
Rule IDs	100201 / 100202 / 100203	Failed login / SSH intrusion / critical activity

8. REFERENCES & RELATED INCIDENTS

- INC-2026-001 — Automated Malware Triage: EICAR Pipeline Validation (VirusTotal integration)
- INC-2026-002 — Unauthorized SSH Access & Post-Compromise Reconnaissance (Brazil, root brute-force)
- INC-2026-003 — Cryptominer Deployment via SSH: 23MB ELF64 'sshd' binary, 37/65 VT engines
- MITRE ATT&CK: T1110 (Brute Force), T1078 (Valid Accounts), T1082 (System Info Discovery), T1497 (Virtualization/Sandbox Evasion), T1059 (Command Interpreter)
- Cowrie Honeypot documentation: cowrie.readthedocs.io
- Wazuh Rule reference: rules 100201, 100202, 100203 — custom Cowrie decoder (cowrie_custom)
- Full project repository: github.com/jacekkaplon/The-Littlefish-Hunter

Jacek Kaplon | SOC Analyst Portfolio [linkedin.com/in/jacek-kaplon](https://www.linkedin.com/in/jacek-kaplon) | github.com/jacekkaplon/The-Littlefish-Hunter